XGR node v3.5.0 BLS possession security delta review

Review ID: XGR-POP-2026-11-06-v1.0.0. **Date:** 6 November 2026. AI-assisted source/execution review by OpenAI GPT-6 Astra Pro. Solana is excluded. This companion is separate from the XITA finding count.

1. Opinion and exact boundary

CONDITIONAL GO within the reviewed possession delta. The known legacy rogue-key admission cause is verified remediated on the frozen source. No additional Critical or High vulnerability was demonstrated in the examined possession admission, migration and validator-selection paths. This statement is not a proof that no bug exists, a whole-node audit, an accredited external certificate or a per-host binary attestation.

The reviewed target is xgr-node a84c82737dc3ca195192a96498eab0e170f8bb5a. The possession baseline is 0d9aca695c49784da64736d78620cc1bba4f7daa. The security source/tag commit is b3717a44b5ec5faa19fabdd88bd4b91f54659983; the later target adds documentation. The broader Interchain comparison begins at 51d92f1ab9b1ba52f62e2ff903c6ff0a7c2f5671 and includes nine commits/65 changed paths. The complete inventory is supplied; inventory is not a numerical line-coverage claim.

The Mainnet gate at height 12,586,649 is already activated. Testnet height 6,613,834 is recorded in the canonical release documentation, not newly exercised on public Testnet here. This review does not authorize a new activation height, replacement manifest, repeated migration, restaking, database reset or rollback to a pre-v3.5.0 node. Normal operation must retain the canonical configuration and proven-key selection.

2. Threat model and known cause

The original defect concerned aggregation of consensus BLS keys admitted without proof that the registrant possessed the corresponding secret. The reviewed fix requires a possession proof at key registration/rotation, authenticates existing keys through the migration manifest, and applies the proven-key restriction to normal and fallback/cached consensus selection. Merely patching the public registration function would not be sufficient if legacy keys or fallback snapshots could bypass admission.

The review therefore followed key material from proof creation through canonical encoding, on-chain verification/storage, pre-transaction migration, epoch selection, historical parent seals and a fresh node importing the fork. It also checked that the unrelated Interchain proof domain is not substituted for a staking proof. No production attack transaction was submitted. New unresolved exploit recipes would remain protected; the current public record describes controls and evidence without claiming unrestricted exploit completeness.

3. Signature and replay boundaries

The proof digest binds XGR_STAKING_BLS_POP_V1, the chain identifier, staking contract address, validator address, public-key hash and registration nonce. The wallet/ECDSA authority and BLS secret remain distinct. Another address, chain, contract, key or used nonce cannot legitimately reuse the proof under these checks. Fresh crypto, contract, CLI and manifest regressions exercise malformed/missing/wrong-context proof rejection and valid ordinary signatures.

Canonical point conversion and verification reject invalid lengths, noncanonical encodings, invalid subgroup/infinity cases covered by the checked tests. The independent legacy aggregate-forgery regression and ordinary-signature controls provide targeted evidence for the original repair. This is an application-level review of the repository's encoding/verifier usage, not a new mathematical proof of the underlying pairing library. The exact dependency and source identities are retained with the frozen repositories.

Source: crypto/staking_pop.go; contracts/staking/StakingV2.sol; consensus/ibft/blspop/manifest.go; consensus/ibft/blspop/rogue_key_test.go; consensus/ibft/blspop/aggregate_review_test.go.

4. Manifest authenticity and complete coverage

The migration manifest uses strict versioned canonical JSON and canonical public key/proof representations, deterministic ordering and duplicate rejection. Digest equality alone is not sufficient: runtime validation also compares the evidence with the parent-state registered inventory and the canonical signing snapshot. The reviewed implementation requires exact coverage, including needed historical snapshot keys; it does not silently accept a quorum-only subset or reduce the quorum when evidence is missing.

Size/key-count bounds prevent unbounded configuration decoding in the reviewed path. Missing, extra, duplicated, malformed or mismatched evidence fails closed. Canonical configuration remains necessary for restart and replay even after the on-chain proof marker is present. Offline verification checks proof/encoding/digest; it must not be described as independently proving parent-state inventory without that state.

Source: consensus/ibft/blspop/manifest.go; chain/params.go; consensus/ibft/staking_pop.go; state/staking_pop.go; command/ibft/blspop/.

5. State transition and storage compatibility

One fork gate jointly activates the reviewed staking runtime, migration and proof-enforced admission. The shared pre-transaction hook executes on proposal and import. The reviewed transition checks its expected legacy state/runtime before applying the deterministic migration, and keeps later validation fail-closed. The appended state is distinct from the existing staking/delegation layout: verified address/key history, registration nonces and the manifest marker are added without replacing existing stake ownership.

The pinned build reproduced the generated ABI, creation/runtime bytecode and storage layout. The legacy prefix and recursively resolved structure layout checks passed. The reviewed runtime is 11,627 bytes with SHA-256 120acc0e54f2af48adcb1518186f39d9a93244a52087927cdf554e7c8cf3f864. Fresh Solidity execution and Go/storage agreement tests cover proof recording, nonce replay, migration idempotence and preservation of stake/balance state. These finite tests do not enumerate every possible mapping state.

Source: state/staking_pop.go; state/executor.go; contracts/staking/pop_artifact.go; contracts/staking/pop-artifact/StakingV2PoP.json; scripts/build-staking-pop.mjs; state/staking_pop_contract_test.go.

6. Consensus selection and historical import

The activation boundary derives signing authority from the appropriate parent view rather than allowing a proposed post-state to authorize itself. Proven-key checks cover normal selection, fallback paths and cached signing sets. ParentCommittedSeals use the rules of the parent's signed height, preserving validation of pre-fork history across the transition. The legacy registration selector is not an accepted post-fork fallback.

Fresh tests exercised activation before/on/after epoch boundaries, restart behavior, cached snapshots, manifest coverage and historical access. The isolated integration test used four validators plus an observer, restarted a validator and synchronized a fresh sixth node from Genesis through the fork. Every participating node agreed at the sampled activation height. This is stronger than a single process accepting its own block but is not a full adversarial network campaign or a fresh Mainnet replay.

Source: consensus/ibft/staking_pop.go; consensus/ibft/fork/manager.go; validators/store/contract/fetcher.go; consensus/ibft/ibft.go; e2e/staking_pop_fork_e2e_test.go.

7. Validator join and operational compatibility

The join CLI detects the reviewed runtime, queries chain ID and the live nonce, creates the proof using the existing local BLS identity and submits the proof-bearing registration. Unknown runtime identity and failed proof registration fail closed instead of reverting to an unproven registration call. A new validator does not edit the historical migration manifest. Existing migrated validators do not need to join again or restake for this fork.

Successful transaction submission is not the same as confirmed registration or active-set eligibility. If a stake transaction succeeded but registration did not, operators must inspect the existing identity/state/receipts rather than generate new keys or duplicate stake blindly. No live join was performed by this audit. The existing chain's support/epoch rules remain outside any implied new admission guarantee.

Source: command/ibft/join/join.go; command/ibft/join/staking_pop_test.go; command/ibft/blspop/; docs/security/v3.5.0-rollout.md.

8. Fresh execution evidence

E-02 is a new execution of bash scripts/validate-v3.5.0.sh on the exact target, not merely a historical CI screenshot. Go 1.23.11, the pinned npm/solc 0.8.30 build, 19 selected package groups and the complete Go build passed. The package list includes chain, crypto, staking artifacts/helpers, state/precompiles, contract validator fetcher, IBFT/fork/signer/manifest, proof/join CLI and Interchain core/EVM/runtime/verification integration.

TestStakingPoP_FourValidatorSingleForkAndFreshSync passed in 77.06 seconds. At isolated activation height 35 the recorded block hash is 0x3aa709ba2640b7a2fb55b5b3a87cea7240db5a165a53c41085739c73ea27335e and state root is 0x762aff52f766767c7829dca5d6c35d2a3c04d02d3306499cdd0e48cf4b26b3f8. These hashes identify this ephemeral test execution; another valid fresh devnet need not produce identical values. Agreement within a run is the tested invariant.

E-04 separately repeats JSON-RPC, Interchain runtime and possession/manifest packages three times; all pass. The isolated fork test disables Interchain workers before construction and uses loopback endpoints/ephemeral identities. No production keys, transfers, deployment or service restart are involved. Broader unrelated whole-repository end-to-end suites were not newly executed and are not claimed covered.

9. Read-only Mainnet observations

E-05 queried both configured XGR RPC endpoints using an explicit read-only method allowlist. Both report xgrchain/v3.5.0/linux-amd64/go1.23.11. Both expose the exact 11,627-byte staking runtime hash above and the migration marker 0x98803459ccdbbf1a8b89d8c44c95081661ebdeb3e037eb0c144126e74ec5d735. They agree on block and state hashes at 12,586,648, 12,586,649 and 12,587,000. Full values and query timestamps are in evidence/read-only-deployments.json.

This is a fresh observation of the queried canonical RPC views, not an independent physical-host attestation. The two URLs can share infrastructure. The earlier canonical release document records five migration keys, per-key proof/nonces and selected unchanged stake/delegation state across the fork; those broader November 5 measurements are retained as documented prior observations, not silently presented as freshly repeated here.

10. Installed binary identity qualification

The canonical release record identifies source/tag b3717a44b5ec5faa19fabdd88bd4b91f54659983 and published asset SHA-256 e11e4398cb0e7757fc2b788f1dde177bd00758329ec52bbc1579f8655604e96e, with Go 1.23.12. The fresh endpoint client strings instead report Go 1.23.11, matching the test toolchain. This does not demonstrate a consensus vulnerability: the observed runtime, marker and sampled history agree. It does mean that the exact installed executable cannot be equated with the documented release asset on the strength of a version string alone.

A targeted existing executable checksum/embedded-commit inventory would resolve this traceability question. No restart, rollback, new migration or new transaction is justified by the missing host digest alone. The source opinion and positive runtime observations remain scoped to what was actually checked.

11. Interchain separation and retained limits

Staking possession and Registry V3/Direct-BLS membership are separate cryptographic domains. This release does not imply new XITA router contracts, new signature wire encodings or Solana support. The test-only interchainRuntimeDisabled option prevents worker construction in isolated tests; it is not another chain fork gate. Configuration/digest consistency remains operationally important on every node.

The companion review does not close XITA availability/trust findings by association with a successful consensus fix. External RPC trust, worker shutdown bounds, durable recovery handoff and optional sponsorship lifecycle remain separately classified in the XITA report. Likewise, green XITA contract tests do not prove the possession migration on arbitrary production history.

12. Acceptance and remaining evidence

The known rogue-key cause is recorded as VERIFIED / RESOLVED for the reviewed source, supported by fresh rejection, ordinary-key, context-binding, state and fork/import evidence. No additional reportable Critical or High cause was demonstrated in the reviewed possession delta. This is a targeted evidence-based conclusion, not a guarantee or an independent audit firm's certificate.

Continue only with the canonical already activated configuration and compatible proven-key enforcement. Retain manifests, keys, datadirs and normal backup/release controls. Resolve installed executable identity through existing host checks where required. Reporter disclosure/advisory closure/rewards remain separate actions and were not performed. No new risk acceptance, production enablement or infrastructure mutation was made by this audit.